1. A firewall receives a TCP SYN packet destined for an internal server. Which factors could influence whether the packet is permitted?

A. Source IP address
B. Destination IP address
C. Destination port
D. Security policy/rule
E. Monitor resolution

2. Which situations demonstrate a limitation of a traditional network firewall?

A. Encrypted malicious traffic may not be inspected
B. An application may misuse an allowed port
C. A compromised internal host may communicate with another internal host
D. It automatically identifies every zero-day vulnerability
E. It may not understand application-layer behavior

3. An organization allows outbound TCP/443 from all systems. Which security concern is most appropriate?

A. HTTPS can carry malicious traffic
B. Command-and-control communication may use HTTPS
C. Port 443 guarantees legitimate traffic
D. Application-layer inspection may be required
E. DNS becomes unnecessary

4. Which characteristics are associated with stateful firewalls?

A. Maintaining connection state
B. Tracking established TCP sessions
C. Making decisions using connection context
D. Automatically preventing all application-layer attacks
E. Allowing rules based only on MAC addresses

5. A company wants to detect suspicious traffic without directly blocking it. Which technology is most appropriate?

A. IDS
B. IPS

C. Network monitoring sensor
D. Passive traffic analysis
E. Stateful firewall alone

6. Which statements correctly differentiate IDS and IPS?

A. IDS is generally detection-oriented
B. IPS can actively block traffic
C. IPS is commonly deployed inline
D. IDS can never generate false positives
E. IDS must always be deployed inline

7. An IDS generates thousands of alerts every day, but analysts investigate very few. What are appropriate responses?

A. Tune detection rules
B. Prioritize alerts based on risk
C. Correlate alerts with asset information
D. Disable the IDS permanently
E. Reduce known benign traffic alerts

8. Which factors can contribute to IDS false positives?

A. Legitimate traffic matching an attack signature
B. Poorly tuned detection rules
C. Unusual but legitimate application behavior
D. Incorrect baseline assumptions
E. Strong encryption automatically

9. Which techniques can make signature-based IDS detection more difficult?

A. Payload obfuscation
B. Fragmentation
C. Encoding
D. Changing attack syntax
E. Using a stronger monitor

10. Why can normalization improve IDS/IPS detection?

A. It can reconstruct fragmented traffic
B. It can reduce representation differences
C. It can make inspection more consistent
D. It automatically patches vulnerable servers
E. It can help detect obfuscated requests

11. Which characteristics are commonly associated with VPN technology?

A. Confidentiality
B. Authentication
C. Integrity protection
D. Secure remote connectivity
E. Guaranteed endpoint security

12. A VPN user successfully authenticates but can access every internal subnet. Which security principles are violated?

A. Least privilege
B. Network segmentation
C. Need-to-know access
D. Defense in depth
E. Data compression

13. Which controls can strengthen remote-access VPN security?

A. Multi-factor authentication
B. Device posture checking
C. Least-privilege access
D. Session monitoring
E. Unlimited internal access

14. Which statements about a proxy server are correct?

A. It can act as an intermediary between client and destination
B. It can enforce web-access policies
C. It can provide logging and monitoring
D. It automatically eliminates malware
E. It can assist in content filtering

15. A proxy detects repeated requests to newly registered suspicious domains. What could this indicate?

A. Malware activity
B. Command-and-control communication
C. Compromised endpoint
D. Potential data exfiltration
E. Guaranteed legitimate browsing

16. Which statements about vulnerability assessment are correct?

A. It can identify known vulnerabilities
B. Automated scanners can produce false positives
C. Results require validation
D. It always proves exploitability
E. It can support remediation prioritization

17. Which activities are generally associated with penetration testing?

A. Controlled exploitation
B. Attack-path validation
C. Privilege-escalation testing
D. Demonstrating business impact
E. Randomly attacking unrelated Internet systems

18. Why is manual validation important after vulnerability scanning?

A. To eliminate false positives
B. To confirm exploitability
C. To understand business impact
D. To identify vulnerabilities missed by scanners
E. Because scanners never detect real vulnerabilities

19. A scanner identifies a critical vulnerability in an isolated test server and a medium vulnerability allowing authentication bypass on a production application. Which factors should influence prioritization?

A. Asset criticality
B. Exploitability
C. Business impact

D. Exposure
E. Scanner severity alone

20.

Which activities normally belong to reconnaissance?

A. Identifying domains
B. Discovering public IP ranges
C. Collecting publicly available information
D. Identifying technologies
E. Modifying production databases

21. Which tools can be used in VAPT activities?

A. Nmap
B. Nessus
C. OpenVAS/Greenbone
D. Burp Suite
E. Wireshark

22. Nmap identifies TCP/22 as open on a server. Which conclusions are justified?

A. SSH may be available
B. The service should be investigated
C. The server is definitely compromised
D. Service/version enumeration may be useful
E. Access must automatically be granted

23. Which information can service/version enumeration provide?

A. Potential software identity
B. Potential software version
C. Possible vulnerability associations
D. Definitive proof that exploitation will succeed
E. Information useful for attack-surface analysis

24. Burp Suite is particularly useful for testing:

A. HTTP requests
B. HTTP responses

C. Web application parameters
D. Authentication workflows
E. Physical network cabling

25. A web application accepts user-controlled input and returns it without proper validation. Which security concerns could arise?

A. Injection
B. Cross-site scripting
C. Input-validation weaknesses
D. Potential session-related attacks
E. Automatic firewall failure

26. Which findings should generally increase the priority of a vulnerability?

A. Internet exposure
B. Active exploitation evidence
C. High-value affected asset
D. Easy exploitation
E. Strong compensating controls

27. A vulnerability scanner reports a high-severity vulnerability, but manual testing finds that the affected component is not actually present. What should happen?

A. Mark it as a false positive
B. Document the validation evidence
C. Avoid unnecessary remediation
D. Automatically exploit another system instead
E. Review scanner configuration

28. Which are examples of defense-in-depth controls?

A. Firewall
B. IDS/IPS
C. Network segmentation
D. Endpoint security
E. Using one password everywhere

29. A web server in a DMZ is compromised. Which controls can reduce the probability of database compromise?

A. Network segmentation
B. Restrictive firewall rules
C. Separate credentials
D. Application-layer access control
E. Direct unrestricted database connectivity

30. Which statements about DMZ architecture are correct?

A. Public-facing systems can be isolated from internal systems
B. DMZ placement can reduce direct exposure of internal systems
C. A DMZ guarantees that a compromised server cannot attack internal systems
D. Firewall policies can control DMZ-to-internal traffic
E. Additional monitoring can be deployed around DMZ systems

31. A company has identical administrator passwords on multiple servers. What risks arise?

A. Credential reuse
B. Lateral movement
C. Single compromised credential affecting multiple systems
D. Increased blast radius
E. Improved segmentation

32. Which measures can reduce lateral movement?

A. Network segmentation
B. Least privilege
C. Privileged access management
D. Unique credentials
E. Unrestricted east-west traffic

33. Which firewall-management practices improve security?

A. Periodic rule review
B. Removing unused rules
C. Documenting rule purpose
D. Restricting overly broad rules
E. Creating permanent allow-any rules

34. A firewall rule allows:

ANY → INTERNAL-SERVER → TCP/443

Which concerns should be investigated?

A. Whether the source should really be ANY
B. Whether the server genuinely requires HTTPS exposure
C. Whether application-layer inspection is needed
D. Whether the rule has an expiration/review process
E. Whether all Internet users should automatically be trusted

35. Which information sources are useful for incident correlation?

A. Firewall logs
B. VPN logs
C. IDS/IPS alerts
D. Proxy logs
E. Authentication logs

36. A VPN login occurs at 3:00 AM from an unusual location, followed by access to several internal servers. Which actions are appropriate?

A. Investigate authentication logs
B. Examine VPN session details
C. Correlate endpoint and firewall logs
D. Consider temporary account containment
E. Ignore the event because authentication succeeded

37. Which statements correctly describe the relationship between VAPT and network security controls?

A. VAPT can identify weaknesses in firewall configurations
B. VAPT can validate IDS/IPS detection capabilities
C. VAPT can identify excessive network exposure
D. VAPT can verify segmentation effectiveness
E. VAPT makes security controls unnecessary

38. During a penetration test, testers discover that a low-severity vulnerability can be chained with another weakness to obtain administrative access. What should be considered?

A. Attack-chain impact
B. Combined exploitability
C. Business impact
D. Individual CVSS score alone
E. Privilege escalation potential

39.

Which practices help ensure that VAPT remains ethical and controlled?

A. Clearly defined scope
B. Written authorization
C. Rules of engagement
D. Defined testing windows
E. Testing unrelated third-party systems without permission

40. An organization wants to improve its security posture after completing VAPT. Which sequence is most appropriate?

A. Identify vulnerabilities
B. Validate findings
C. Prioritize based on risk
D. Remediate
E. Perform verification/retesting

41. A firewall contains the rule:

ANY → Web Server → TCP 443 → ALLOW

Which security concerns should an administrator investigate?

A. Whether unrestricted source access is necessary
B. Whether the web server is properly hardened
C. Whether HTTPS traffic requires application-layer inspection
D. Whether the rule should be periodically reviewed
E. Whether TCP 443 is inherently malicious

42. An organization places an IDS outside the firewall and an IPS between the DMZ and internal network. An attacker compromises a DMZ server and attempts to communicate with an internal database.

Which statements are correct?

A. The IDS can generate an alert about suspicious communication
B. The IPS may block the communication
C. Network segmentation can reduce the attack path
D. The firewall can enforce restrictions between DMZ and internal networks
E. The IDS automatically prevents the compromise

43. A VAPT team discovers four vulnerabilities:

- Critical vulnerability on an isolated test server
- High vulnerability on an Internet-facing web server
- Medium vulnerability allowing authentication bypass
- Low vulnerability on a database containing sensitive information

Which factors should influence prioritization?

A. Asset criticality
B. Internet exposure
C. Exploitability
D. Potential business impact
E. CVSS/severity rating alone

44. A company discovers that an employee's VPN credentials were stolen and subsequently used to access internal resources.

Which controls could reduce the likelihood or impact of such an incident?

A. Multi-factor authentication
B. Device posture verification
C. Least-privilege VPN access
D. Monitoring unusual VPN login behavior
E. Giving VPN users unrestricted internal access

45. A corporate proxy detects that an employee workstation repeatedly contacts multiple newly registered domains and sends unusually long encoded parameters.

Which possibilities should the SOC investigate?

A. Malware infection
B. Command-and-control communication

C. Possible data exfiltration
D. Compromised endpoint
E. Guaranteed legitimate browsing

46. Before conducting an authorized penetration test against an organization's infrastructure, which activities are important?

A. Defining the testing scope
B. Obtaining written authorization
C. Establishing rules of engagement
D. Defining testing windows and restrictions
E. Testing any third-party system discovered during reconnaissance

47. A company wants to prevent compromise of a public web server from directly exposing its database.

Which measures are appropriate?

A. Place the web server in a DMZ
B. Restrict DMZ-to-database traffic
C. Use separate authentication credentials
D. Apply firewall rules between network zones
E. Allow unrestricted communication between the web and database servers

48. A vulnerability scanner reports 50 vulnerabilities, but manual validation confirms that 12 are false positives.

Which conclusions are correct?

A. Automated scanning can generate false positives
B. Manual validation improves confidence in findings
C. All scanner results should automatically be treated as exploitable
D. Validated findings should be prioritized according to risk
E. Scanner output should be reviewed before remediation decisions

49. During a penetration test, an attacker exploits an exposed web application, obtains limited access, discovers reused administrator credentials, and subsequently accesses an internal database.

Which concepts are demonstrated?

A. Initial compromise
B. Credential reuse
C. Lateral movement
D. Attack chaining
E. Effective network segmentation

50. An organization wants to improve protection against external attacks and lateral movement.

Which combination provides the strongest defence-in-depth approach?

A. Firewall with restrictive rules
B. IDS/IPS for detection and prevention
C. Segmented internal networks
D. MFA-enabled VPN with least-privilege access
E. Regular VAPT and remediation
F. A single firewall with unrestricted internal access

Case Study 1:

A university has a firewall separating the Internet, DMZ, and internal network. Its public web server is located in the DMZ, while the database server is inside the internal network. An IDS monitors traffic and an IPS protects the internal network. During an incident, the firewall logs

show repeated connection attempts against ports 22, 80, 443, and 3306. HTTPS traffic is permitted, and the web server subsequently establishes unusual outbound connections to an unknown external IP. Later, the database server receives multiple connection attempts from the web server.

Questions

1. Which security zone contains the initially targeted web server?
2. Which device should primarily control traffic from the Internet to the DMZ?
3. What type of activity is represented by repeated attempts against multiple ports?
4. Why might the firewall allow the attacker's HTTPS traffic?
5. Which security device is primarily responsible for detecting suspicious traffic?
6. What does communication from the web server to the database suggest?
7. Which security principle can prevent unrestricted web-server-to-database communication?
8. What type of attack could occur if the compromised web server is used to attack the database?

Case Study 2:

An e-commerce company authorizes a VAPT team to assess its public website and API. The team first performs reconnaissance and Nmap-based service enumeration, followed by automated vulnerability scanning using Nessus/OpenVAS. Burp Suite is then used for web-application testing. The scanner reports a critical vulnerability in an outdated component, but manual validation shows that the component is not actually installed. A medium-severity authentication flaw, however, allows unauthorized access to customer information.

Questions

1. Which VAPT phase involves collecting information before active testing?
2. Which tool can be used for port and service enumeration?
3. Which tools can perform automated vulnerability scanning?
4. Why should the reported critical vulnerability be manually validated?
5. What type of scanner result is the critical finding in this case?
6. Which vulnerability should receive greater attention: the false-positive critical finding or authentication bypass?
7. Which tool is particularly suitable for intercepting and modifying HTTP requests?
8. What security impact does authentication bypass potentially create?

Case Study 3:

A financial organization provides employees with SSL VPN access. One employee's account logs in at 3:00 AM from an unusual location and immediately accesses several internal file servers. The same endpoint generates hundreds of requests through the corporate proxy to newly registered domains. Firewall logs show permitted HTTPS connections, while the IDS reports suspicious outbound communication.

Questions

1. Which technology provides secure remote access to internal resources?
2. What authentication-related indicator is suspicious in this case?
3. Which log should be examined to verify the employee's remote session?
4. What could repeated communication with newly registered domains indicate?
5. Why does the firewall permit the suspicious HTTPS traffic?
6. Which security device detected suspicious network behavior?
7. Which principle is violated if the VPN account can access every internal server?
8. What authentication mechanism can strengthen VPN security?

Case Study 4:

During an authorized penetration test, a security team sends a known malicious request toward a web application. The IDS detects the request when it is transmitted normally. However, when the same payload is fragmented and encoded differently, the IDS fails to generate an alert. The IPS blocks the original request but allows some modified versions. The firewall permits TCP port 443 because the application requires HTTPS.

Questions

1. Which security system initially detected the malicious request?
2. Which system attempted to block the malicious request?
3. What technique was used by the testers to alter packet delivery?
4. What technique was used to change the representation of the payload?
5. What type of IDS detection is particularly vulnerable to known-signature modification?
6. Why does an open port 443 not prove that the application is secure?
7. What capability can help IDS/IPS detect fragmented attacks more reliably?
8. Which VAPT activity can be used to test IDS/IPS effectiveness?

Case Study 5:

A research organization uses a firewall, IDS/IPS, VPN and proxy server. A VAPT assessment discovers that several servers run unnecessary services, administrators use identical passwords across multiple servers, and VPN users can access almost every internal subnet. The firewall contains more than 500 old rules, while the IDS produces thousands of alerts that are rarely investigated. A penetration test demonstrates that compromising one web server eventually allows access to the database server.

Questions

1. What vulnerability is created by using identical passwords on multiple servers?
2. What security principle is violated by unrestricted VPN access?
3. What technique can reduce communication between different internal network segments?
4. What should be done with unnecessary running services?
5. What should be performed periodically on old firewall rules?
6. What problem is indicated by thousands of uninvestigated IDS alerts?
7. What type of movement occurs when an attacker moves from the web server toward the database?
8. Which VAPT activity should be performed after remediation?